

Cloud Security Operations & Incident Response

Centralized Logging & Automated Alerting, Microsoft Defender for Cloud Security Monitoring, a Security Dashboard, and a Tested Cloud Incident Response Playbook

Scenario organization: Horizon Valley Medical Center (HVMC)

Capstone project: AccessGuard Health — Microsoft Entra ID & Azure IAM Operations

Rubric item: Cloud Security Operations & Incident Response (Cloud Security 1)

Cloud platform: Microsoft Azure (Resource Group `HVMC-CloudSecurity-RG`)

Builds on: Compliance Auditing Basics, Documentation & Reporting, Legal & Ethical Implementation, and Cloud Compliance & Governance Controls submissions for this same Azure environment

Report date: October 7, 2026

Created by: Sabitha S Karanavar

This submission is prepared as a classroom lab exercise for the HVMC simulation used in this capstone. Configuration descriptions and the incident response test below are illustrative/simulated against the lab's Azure subscription and do not describe a live production tenant or an actual security incident.

Rubric Cross-Reference

Rubric Requirement	Where Addressed
Configure centralized logging (CloudTrail/VPC Flow Logs equivalent) with automated alerting for security events	Section 1 — Centralized Logging & Automated Alerting
Implement security monitoring using GuardDuty or equivalent tools	Section 2 — Security Monitoring (Microsoft Defender for Cloud)
Create security dashboards with key metrics	Section 3 — Security Dashboard
Develop and test a cloud incident response playbook covering identification, containment, investigation, eradication, and recovery, with evidence of playbook testing and documentation	Section 4 — Cloud Incident Response Playbook & Tabletop Test

Platform note: this rubric item names AWS-specific services (CloudTrail, VPC Flow Logs, GuardDuty). HVMC's actual lab environment for this capstone is built on **Microsoft Azure**. This document satisfies the same monitoring and incident-response requirements using Azure's native equivalents — **Azure Activity Log + Diagnostic Settings** in place of CloudTrail, **NSG Flow Logs** (via Network Watcher) in place of VPC Flow Logs, **Microsoft Defender for Cloud** in place of GuardDuty, and **Azure Monitor Alert rules + Action Groups** in place of EventBridge + SNS.

This submission completes the Azure governance arc built across this project's compliance series: the log-retention gap identified in *HVMC_Compliance_Auditing_Basics.pdf* is closed by the Diagnostic Settings retention configuration in Section 1; the Management Group structure from *HVMC_Cloud_Compliance_and_Governance_Controls.pdf* hosts the Microsoft Defender for Cloud plan administration in Section 2; and the incident response playbook in Section 4 is tested directly against the same "orphaned Azure account" incident scenario documented in *HVMC_Legal_and_Ethical_Implementation.pdf* (Section 4), rather than a generic, disconnected example.

1. Centralized Logging & Automated Alerting

1.1 Azure Activity Log & Diagnostic Settings

- A **subscription-wide Diagnostic Setting** is configured from the Security Management Group (delegated administration), applying to every resource group under the Production-Workloads and Sandbox Management Groups established in the Cloud Compliance & Governance Controls submission, so no resource group can opt out of logging.
- Captures the full Activity Log category set (Administrative, Security, Alert, Policy) plus resource-level diagnostic logs for the resources in `HVMC-CloudSecurity-RG`, scoped to the data-handling resources that are the ePHI-adjacent path.

- Delivered to both a **Log Analytics workspace** (real-time KQL query and alerting) and an **Azure Storage account** with immutability policy enabled (long-term, tamper-evident archival) in parallel.
- **Retention:** the Log Analytics workspace is configured for interactive retention plus an Azure Storage lifecycle management policy that moves archived logs to the Archive access tier after 1 year and expires them at 6 years, directly closing the log-retention finding (Control 2) from the Compliance Auditing Basics audit.

1.2 NSG Flow Logs (Network Watcher)

- Enabled at the network security group level for **HVMC-Web-NSG** , **HVMC-App-NSG** , and **HVMC-Data-NSG** , using **Version 2 flow logs** so both allowed and denied connections are captured — denied-connection volume is what feeds the security dashboard in Section 3.
- Flow logs are processed through **Traffic Analytics** (also Network Watcher) and delivered to the same Log Analytics workspace as the Activity Log, so both can be queried together with KQL during an investigation (used directly in the Section 4 playbook test).

1.3 Automated Alerting

Triggering Event	Source	Mechanism	Notification Target	Severity
Global Administrator sign-in or privileged role activation	Entra ID sign-in log / Activity Log	Azure Monitor alert rule	Action Group: security-critical	CRITICAL
Azure Policy assignment or role-assignment change	Activity Log	Azure Monitor alert rule	Action Group: security-high	HIGH
NSG rule opened to 0.0.0.0/0 on a sensitive port	Azure Policy / Activity Log	Azure Monitor alert rule	Action Group: security-high	HIGH
Microsoft Defender for Cloud alert, severity High or above	Defender for Cloud	Native Azure Monitor integration	Action Group: security-critical	CRITICAL
Spike in NSG Flow Log denied-connection entries	NSG Flow Logs / Traffic Analytics	Log Analytics scheduled query alert	Action Group: security-medium	MEDIUM

Each Action Group fans out to the on-call Incident Response channel (acting role, via email/SMS/webhook) and is logged to the same evidence repository used for the Documentation & Reporting submission's record-management procedures.

2. Security Monitoring (Microsoft Defender for Cloud)

2.1 Configuration

Microsoft Defender for Cloud is enabled subscription-wide with its plan administration seated in the Security Management Group (the same scope hosting the centralized Log Analytics workspace), and Defender plans are set to auto-enable for any new resource group added under the subscription. The **Defender for Servers**, **Defender for Storage**, **Defender for Key Vault**, and **Defender for Containers** plans are active, supplementing the foundational Activity Log/NSG Flow Log/DNS analytics data sources already in Section 1.

2.2 Finding Categories Monitored

Defender for Cloud Alert	What It Indicates	Severity	Initial Response
"Sign-in from an unfamiliar location for a privileged account"	A Global Administrator or Owner-role account signed in from an atypical location/device	CRITICAL	Immediate escalation to Incident Commander
"Suspicious use of a Managed Identity credential detected"	Credentials from a VM's managed identity are being used outside the resource	HIGH	Suspend the identity; begin containment (Section 4)
"Traffic from a known malicious IP address was detected"	Inbound/outbound traffic involving an IP on a known-malicious threat list	MEDIUM	Investigate source and affected resource
"Detected communication with a possible command and control server"	A VM is communicating with a known command-and-control host	CRITICAL	Isolate the instance immediately
"Digital currency mining activity detected"	A VM is running cryptocurrency-mining software	HIGH	Isolate and snapshot for investigation

2.3 Integration with Alerting

Defender for Cloud alerts publish natively to Azure Monitor, which routes Medium-and-above findings into the same Action Group-based alerting pipeline built in Section 1.3 — Defender for Cloud does not run as an isolated tool with its own separate notification path.

3. Security Dashboard

An Azure Monitor Workbook, [HVMC - Security - Operations](#), gives the IAM/Identity Administrator and Compliance Auditor one screen covering logging health, active threats, and governance compliance together:

Defender for Cloud Alerts by Severity

Activity Log Event Volume

Azure Policy Compliance Ratio

7-day rolling count, Low/Medium/High/Critical — source: Microsoft Defender for Cloud	Events/hour with an anomaly band, flags unusual management-plane activity spikes — source: Activity Log via Log Analytics	Compliant vs. non-compliant resources against the policies in the Governance Controls submission — source: Azure Policy
Failed / Privileged Sign-ins Count of failed sign-ins and any Global Administrator sign-ins in the period — source: Entra ID sign-in logs	NSG Flow Log Denied Connections Rolling count of denied entries, the input to the Section 1.3 spike alarm — source: NSG Flow Logs / Traffic Analytics	Open Remediation Findings Same KPI as the Documentation & Reporting quarterly report, by risk rating — source: remediation tracker

Metric	Refresh Cadence	Owner
Defender for Cloud alerts, Activity Log volume, NSG Flow Log denies	Near real-time (5 min)	IAM/Identity Administrator (on-call)
Azure Policy compliance ratio	Hourly (on each policy evaluation cycle)	IAM/Identity Administrator
Open remediation findings	Weekly	Compliance Auditor

4. Cloud Incident Response Playbook & Tabletop Test

4.1 Playbook Procedures

1. Identification

Objective: confirm a security event has occurred and establish its scope.

Key actions: triage the Defender for Cloud/Activity Log alert from Sections 1–2; confirm the affected resource group, resource, and identity; assign an incident severity and open an incident ticket; notify the Incident Commander (acting role).

Evidence: Defender for Cloud alert ID, Activity Log correlation ID, incident ticket number.

2. Containment

Objective: limit further damage without destroying evidence.

Key actions: disable (not delete) the implicated Entra ID account or managed identity; assign a "deny all" Azure custom role at the resource group scope for that principal; snapshot affected disks before any further change; rotate any Key Vault secrets the identity could have reached.

Evidence: timestamp of account disablement, custom role assignment ID, disk snapshot IDs.

3. Investigation

Objective: determine root cause, scope of access, and whether ePHI was involved.

Key actions: pull the full Activity Log and Entra ID sign-in history for the identified principal via Log Analytics KQL; cross-reference NSG Flow Logs for associated network activity; apply the HIPAA four-factor breach risk assessment (45 CFR §164.402, as used in the Legal & Ethical Implementation submission) to determine reportability; preserve a documented chain of custody for all evidence collected.

Evidence: Log Analytics query export, NSG Flow Log excerpt, completed breach risk assessment.

4. Eradication

Objective: remove the attacker's access and the underlying root cause.

Key actions: fully deprovision the compromised/orphaned Entra ID account (not just disable it); confirm the Azure Policy and tagging controls from the Governance Controls submission would prevent an equivalent unowned account going forward; re-run the relevant Azure Policy compliance scan to confirm the resource is now compliant.

Evidence: Entra ID deprovisioning confirmation, Azure Policy re-evaluation result (**Compliant**).

5. Recovery

Objective: restore normal operations with confidence the issue will not recur.

Key actions: reissue any legitimate access under new, correctly-owned, least-privilege Azure RBAC role assignments; place the affected resources under a 14-day heightened-monitoring window on the Section 3 dashboard; close the incident ticket; update the remediation tracker; carry a lessons-learned summary into the next quarterly compliance status report.

Evidence: closure timestamp, updated remediation tracker entry, lessons-learned note.

4.2 Playbook Test — Tabletop Exercise

This playbook was tested as a tabletop exercise walking the exact scenario documented in the Legal & Ethical Implementation submission (Section 4): *Unauthorized Access via an Orphaned Azure Account*. The table below is the test record, retained as the evidence of playbook testing this rubric item asks for.

Elapsed Time	Phase	Action Taken	Participant (acting role)	Outcome
T+0 min	Identification	Defender for Cloud alert and Activity Log entry reviewed; incident ticket opened	IR Analyst	Confirmed as a Security Incident
T+5 min	Containment	Orphaned Entra ID account disabled; deny-all custom role assigned at resource group scope	IAM/Identity Administrator	No further sign-in activity observed from the principal
T+20 min	Investigation	Full Activity Log and sign-in history pulled for the principal; HIPAA four-factor breach test applied	Compliance Auditor	Breach presumption not rebutted — classified Reportable, matching Legal & Ethical §4.1
T+45 min	Eradication	Orphaned account fully deprovisioned; Require-Resource-Tags/Owner enforcement re-confirmed	IAM/Identity Administrator	Azure Policy re-evaluation returned Compliant
T+60 min	Recovery	Incident closed; remediation tracker updated; 14-day heightened-monitoring window opened	Compliance Auditor	Normal operations confirmed; lessons learned logged

4.3 Test Documentation & Lessons Learned

The test confirmed all five phases executed in the stated order and within a 60-minute window end to end. One improvement was identified: containment currently requires a manual step to disable the Entra ID account, which could be automated with an **Azure Automation runbook** triggered directly from the Section 1.3 Azure Monitor alert rule, cutting the containment step from 5 minutes to under 1. This test record — the phase table above, with its timestamps

and participants — is itself retained under the 6-year record-retention schedule established in the Documentation & Reporting submission, as the playbook's evidence of testing.

Sources: HVMC_Compliance_Auditing_Basics.pdf, HVMC_Legal_and_Ethical_Implementation.pdf, and HVMC_Cloud_Compliance_and_Governance_Controls.pdf (companion submissions); Microsoft Learn, Microsoft Defender for Cloud and Azure Monitor documentation. Prepared as the Cloud Security Operations & Incident Response deliverable for the Semester 4 Healthcare IAM Operations Home Lab capstone.